

Rapport d'Audit de Sécurité

Client: Nexoryx Bank

Type d'audit: Pentest Réseau

Date: 12/01/2025

Auditeur: Ibrahim Bamba

Version: 1.0

Généré le 04/12/2025 à 00:55

Résumé Exécutif

L'audit de pénétration réseau réalisé pour Nexoryx Bank a mis en lumière plusieurs vulnérabilités significatives qui, si elles étaient exploitées, pourraient avoir un impact majeur sur nos opérations, notre réputation et notre conformité réglementaire. Sur un total de 6 findings identifiés, nous avons relevé **2 vulnérabilités critiques** et **3 vulnérabilités à haute priorité**, indiquant une exposition préoccupante. La principale préoccupation réside dans l'**absence de segmentation réseau adéquate**. Cette lacune critique signifie qu'une fois qu'un attaquant parvient à pénétrer le réseau (par exemple, via un port non sécurisé ou un système non patché), il pourrait potentiellement se déplacer librement à travers l'ensemble de l'infrastructure, accédant ainsi à des systèmes critiques, des données clients sensibles et des informations financières sans entrave. Combinées à un **firewall obsolète** et à l'**absence d'authentification multi-facteurs (MFA)** sur des points d'accès clés, ces vulnérabilités créent un environnement où le risque d'une compromission majeure est élevé. Un attaquant pourrait non seulement exfiltrer des données, mais aussi perturber nos services bancaires, entraînant des pertes financières directes, des amendes réglementaires et une érosion significative de la confiance de nos clients.

Impact Métier et Risques Business Les vulnérabilités identifiées exposent Nexoryx Bank aux risques suivants :

- Risque Financier Élevé :** Potentiel de fraudes massives, de rançongiciels entraînant des coûts de remédiation exorbitants, et de lourdes amendes pour non-conformité aux réglementations bancaires et de protection des données (ex: GDPR).
- Risque Réputationnel Sévère :** Une brèche de données ou une interruption de service majeure pourrait détruire la confiance des clients et des partenaires, impactant directement notre image de marque et notre capacité à attirer de nouveaux clients.
- Risque Opérationnel :** Interruption prolongée des services bancaires essentiels, entraînant des pertes de revenus et une incapacité à servir nos clients.
- Risque Légal et de Conformité :** Non-respect des exigences réglementaires strictes du secteur bancaire, pouvant entraîner des sanctions légales et des poursuites judiciaires.

Niveau de risque global: **Critical**

Sévérité	Nombre
Critical	2
High	3
Medium	1
Low	0

Recommandations prioritaires:

- Mettre en œuvre une Segmentation Réseau Robuste (Critique) : Isoler les systèmes critiques et les données sensibles du reste du réseau. Cela limitera la propagation d'une attaque et protégera nos actifs les plus précieux.
- Renforcer la Sécurité Périmétrique (Haute) : Mettre à jour ou remplacer les firewalls obsolètes et fermer tous les ports réseau non essentiels ou non sécurisés. Cela réduira drastiquement les points d'entrée pour les attaquants externes.
- Déployer l'Authentification Multi-Facteurs (MFA) (Haute) : Implémenter le MFA pour tous les accès à distance, les accès aux systèmes critiques et, à terme, pour l'ensemble des utilisateurs.

Cela protège contre le vol de identifiants et l'accès non autorisé.

4. Assainir les Comptes Utilisateurs (Moyenne) : ** Mettre en place un processus régulier de revue et de désactivation des comptes dormants ou inutilisés afin de réduire les vecteurs d'attaque internes.

Timeline de remédiation:

Nous proposons la timeline suivante pour la mise en œuvre de ces recommandations, en fonction de leur criticité et de leur impact potentiel : * **Actions Critiques (Segmentation Réseau) : ** * **Planification et début d'implémentation : ** Sous **2 semaines**. Une feuille de route détaillée avec des jalons clairs est impérative. * **Implémentation initiale des zones critiques : ** Sous **2 mois**. * **Actions à Haute Priorité (Firewall, Ports, MFA) : ** * **Mise à jour/Remplacement Firewall et fermeture des ports : ** Sous **1 mois**. * **Déploiement MFA sur les accès critiques : ** Sous **1 mois**. * **Actions à Priorité Moyenne (Comptes Dormants) : ** * **Audit et assainissement initial des comptes : ** Sous **2 mois**. * **Mise en place d'un processus de revue continue : ** Sous **3 mois**. Nous sommes à votre disposition pour discuter de ces résultats en détail et pour vous accompagner dans la mise en œuvre de ces mesures essentielles à la protection de Nexoryx Bank.

Contexte & Périmètre

Environnement Pentest Réseau pour Nexoryx Bank

Périmètre technique: Réseau interne + VPN

Périmètre temporel: Audit réalisé le 2025-01-12

Méthodologie

Type d'audit: Pentest Réseau

Standards utilisés: OWASP, PTES, OSSTMM

Approche méthodologique pour Pentest Réseau

Analyse Globale

Score de sécurité: 20.8/100

Score de sécurité: 20.8/100

Distribution par sévérité:

- Critical: 2
- High: 3
- Medium: 1
- Low: 0

Findings Détaillés

Finding #1: Port non sécurisé ouvert

Catégorie: Network

Sévérité: High

Priorité: P1

Description:

La vulnérabilité "Port non sécurisé ouvert" indique que plusieurs points d'entrée réseau (ports) sont exposés sur l'infrastructure de Nexoryx Bank, alors qu'ils ne sont pas activement utilisés ou ne devraient pas être accessibles depuis l'extérieur. Un port réseau est une porte logique sur un serveur ou un équipement réseau, permettant à des services spécifiques (comme la navigation web, l'envoi d'e-mails, la gestion à distance) de communiquer. L'exposition de ports "inutilisés" est particulièrement dangereuse car ces services sont souvent oubliés, mal configurés par défaut, ou ne bénéficient pas du même niveau de surveillance et de durcissement que les services critiques. Ces ports peuvent héberger des services de gestion à distance (SSH, RDP, Telnet), des bases de données (SQL, Oracle), des serveurs de fichiers (SMB, FTP), des interfaces d'administration web, ou même des services de développement laissés ouverts par inadvertance. Un attaquant peut scanner ces ports pour identifier les services sous-jacents, leurs versions et les systèmes d'exploitation. Cette phase de reconnaissance est cruciale pour un attaquant, car elle lui permet de cartographier l'infrastructure et d'identifier des vulnérabilités connues (CVE) associées à ces services ou à leurs configurations par défaut. L'exploitation de ces vulnérabilités pourrait mener à l'exécution de code arbitraire, à l'élévation de privilèges, ou à la compromission complète du système hébergeant le port. Dans le contexte de Nexoryx Bank, opérant dans le secteur des Télécoms, la présence de ports non sécurisés représente un vecteur d'attaque direct vers des infrastructures critiques. Un attaquant pourrait utiliser ces points d'entrée pour établir une persistance, pivoter vers des segments réseau plus sensibles (contenant des données clients, des systèmes de facturation, ou des infrastructures de communication), ou lancer des attaques par déni de service (DoS) contre des services exposés. La nature "non sécurisée" des ports implique souvent l'absence d'authentification forte, l'utilisation de protocoles obsolètes et vulnérables, ou des configurations par défaut qui n'ont pas été durcies, rendant l'exploitation d'autant plus aisée pour un acteur malveillant. ### 2.

Impact métier:

L'impact métier de cette vulnérabilité est potentiellement sévère et multifacette pour Nexoryx Bank, allant bien au-delà des simples considérations techniques. La compromission d'un système via un port non sécurisé peut entraîner une **violation de données massives**, exposant des informations financières et personnelles sensibles des clients (conformément au RGPD et aux réglementations sectorielles). Cela se traduirait par des **amendes réglementaires substantielles**, des **coûts juridiques élevés** liés aux recours collectifs, et des **dépenses considérables pour la réponse à incident** (investigation forensique, remédiation, communication de crise). Pour une banque et un opérateur télécom, la confiance des clients est primordiale ; une telle brèche éroderait gravement la **réputation** de Nexoryx, entraînant une **perte de clientèle significative** et une **baisse de la valeur de la marque** sur le marché concurrentiel. Au-delà de la fuite de données, une compromission pourrait entraîner une

****interruption des services de communication critiques**** ou des ****systèmes bancaires essentiels****. Cela se traduirait par une ****perte de revenus directe**** due à l'indisponibilité des services, des ****pénalités contractuelles**** envers les partenaires, et une ****insatisfaction client généralisée****. L'accès non autorisé pourrait également permettre à un attaquant de manipuler les systèmes de facturation, de détourner des fonds, ou de saboter l'infrastructure, causant des ****dommages opérationnels irréversibles**** et mettant en péril la continuité des activités. Enfin, la gestion d'un tel incident détournerait des ressources internes précieuses, impactant la productivité et la capacité d'innovation de l'entreprise. #### 3.

Recommandation:

La correction de cette vulnérabilité nécessite une approche structurée et rigoureuse, combinant des actions immédiates et des mesures préventives à long terme. ****1. Identification et Cartographie Détaillée (Phase d'Audit Interne)**** * ****Scanner l'ensemble du réseau :**** Utiliser des scanners de vulnérabilités et des outils de cartographie réseau (ex: Nmap, Nessus, Qualys) pour identifier tous les ports ouverts sur les systèmes internes et externes. * ****Corréler avec l'inventaire des actifs :**** Comparer les ports ouverts détectés avec l'inventaire des services et applications légitimes. Tout port ouvert sans justification documentée doit être considéré comme suspect. * ****Interroger les équipes :**** Collaborer avec les équipes d'exploitation, de développement et d'architecture pour comprendre la finalité de chaque service écoutant sur un port et déterminer s'il est réellement nécessaire et s'il est configuré de manière sécurisée. ****2. Remédiation Immédiate et Durcissement (Phase de Correction)**** * ****Fermeture des ports inutilisés :**** Pour tout port identifié comme non essentiel ou non autorisé, la première action est de désactiver le service associé ou de fermer le port au niveau du système d'exploitation ou du pare-feu hôte. * ****Filtrage par pare-feu (Firewall Rules) :**** * ****Pare-feu périmétrique :**** Configurer les pare-feu de bordure pour bloquer tout le trafic entrant et sortant vers les ports non essentiels. Appliquer le principe du moindre privilège : n'autoriser que le trafic strictement nécessaire, depuis des adresses IP sources spécifiques et vers des destinations spécifiques. * ****Pare-feu internes/segmentation :**** Mettre en œuvre une segmentation réseau robuste (VLANs, micro-segmentation) pour isoler les systèmes critiques et limiter la propagation latérale en cas de compromission. Les pare-feu internes doivent également appliquer des règles strictes entre les segments. * ****Pare-feu hôtes :**** S'assurer que les pare-feu logiciels (ex: `iptables` sur Linux, Windows Defender Firewall) sont activés et correctement configurés sur chaque serveur pour restreindre l'accès aux ports. * ****Durcissement des services nécessaires :**** Pour les ports qui *doivent* rester ouverts (ex: 443 pour HTTPS, 22 pour SSH), il est impératif de : * ****Mettre à jour les logiciels :**** Appliquer toutes les mises à jour et correctifs de sécurité pour les services écoutant sur ces ports. * ****Désactiver les fonctionnalités inutiles :**** Supprimer ou désactiver les modules, extensions ou fonctionnalités par défaut qui ne sont pas essentiels. * ****Authentification forte :**** Imposer des mots de passe complexes, l'authentification multi-facteurs (MFA) pour les accès administratifs, et l'utilisation de clés SSH plutôt que des mots de passe. * ****Chiffrement :**** Utiliser des protocoles de communication sécurisés (TLS 1.2/1.3 pour HTTPS, SSHv2) et des suites cryptographiques robustes. * ****Journalisation et surveillance :**** Activer la journalisation détaillée des accès et des activités sur ces services et intégrer ces logs dans un système SIEM pour une détection rapide des anomalies. ****3. Prévention et Maintien (Phase Continue)**** * ****Politique de gestion des ports :**** Établir une politique claire pour l'ouverture et la fermeture des ports, incluant un processus de validation formel, une documentation obligatoire et des revues périodiques. * ****Gestion des changements :**** Intégrer la gestion des ports dans le processus de gestion des changements (Change Management) pour s'assurer que toute modification est revue, approuvée et documentée. * ****Audits et pentests réguliers :**** Réaliser des audits de sécurité et des tests d'intrusion externes et internes de manière régulière pour identifier de nouvelles expositions ou des régressions. * ****Sensibilisation et formation :**** Former les équipes

techniques (DevOps, Ops, Sécurité) aux bonnes pratiques de sécurisation des systèmes et à l'importance de la gestion des ports. * **Architecture "Zero Trust"** : Évoluer vers une architecture de sécurité "Zero Trust" où aucun utilisateur, appareil ou application n'est implicitement fiable, quel que soit son emplacement, et où chaque tentative d'accès est vérifiée. **Priorité d'action : Haute** Cette vulnérabilité est classée comme "Haute" car elle représente un point d'entrée direct pour un attaquant, avec un potentiel d'impact métier très significatif (fuite de données, interruption de service, perte financière et réputationnelle). La correction doit être initiée sans délai.

Finding #2: Absence de segmentation

Catégorie: Network

Sévérité: Critical

Priorité: P0

Description:

L'absence de segmentation réseau, souvent désignée par l'expression "réseau plat", signifie que l'ensemble de l'infrastructure de Nexoryx Bank est configuré comme un seul et même domaine de diffusion logique. En d'autres termes, tous les serveurs, postes de travail, équipements réseau, bases de données et applications critiques peuvent communiquer directement entre eux sans aucune restriction imposée par des pare-feu internes, des VLANs (Virtual Local Area Networks) ou des listes de contrôle d'accès (ACLs) inter-segments. Cette configuration est comparable à une maison sans portes ni serrures entre les pièces : une fois qu'un intrus est à l'intérieur, il a un accès illimité à toutes les pièces, du salon à la chambre forte. Dans le contexte de Nexoryx Bank (secteur Telecom), cela signifie qu'une compromission initiale d'un système, même de faible criticité (par exemple, un poste de travail utilisateur via une attaque de phishing, ou un serveur web public vulnérable), offre à l'attaquant un point d'entrée direct et sans entrave vers l'ensemble des systèmes internes. Cela inclut les systèmes de gestion de la clientèle (CRM), les bases de données d'abonnés, les systèmes de facturation (BSS), les plateformes de gestion des opérations réseau (OSS), les contrôleurs de domaine, et même les équipements critiques de l'infrastructure télécom elle-même. Les vecteurs d'attaque sont multiples : après une première intrusion, l'attaquant peut effectuer des scans réseau complets, découvrir des services vulnérables, exploiter des faiblesses de configuration ou des identifiants faibles sur n'importe quel système, et se déplacer latéralement à travers l'infrastructure sans rencontrer de barrières de sécurité internes. ### 2.

Impact métier:

L'impact métier de cette vulnérabilité est **critique** et potentiellement dévastateur pour Nexoryx Bank. En cas de succès d'une attaque, les conséquences iraient bien au-delà des simples problèmes techniques : * **Impact Financier Direct** : Une intrusion non segmentée peut entraîner le déploiement rapide de rançongiciels sur l'ensemble de l'infrastructure, paralysant les opérations critiques (facturation, support client, gestion du réseau). Les coûts de rançon, de récupération des données, de reconstruction des systèmes et la perte de revenus due à l'interruption de service pourraient se chiffrer en millions d'euros. De plus, la fuite de données clients (informations personnelles, données de consommation, détails de facturation)

entraînerait des amendes réglementaires massives (conformément au RGPD et aux réglementations spécifiques aux télécoms) et des coûts juridiques liés aux actions en justice des clients. * **Impact Réputationnel et Perte de Confiance** : Une brèche de sécurité majeure et généralisée, rendue possible par l'absence de segmentation, entamerait gravement la confiance des clients et des partenaires. La réputation de Nexoryx Bank en tant qu'opérateur fiable et sécurisé serait irrémédiablement ternie, entraînant une perte significative de clientèle au profit de concurrents et une difficulté accrue à attirer de nouveaux abonnés. L'image de marque serait durablement affectée, impactant la valeur boursière et la capacité à lever des fonds. * **Impact Opérationnel et Continuité de Service** : La compromission de l'ensemble du réseau peut entraîner une interruption totale ou partielle des services de télécommunication, y compris la voix, les données mobiles et l'accès internet. Pour un opérateur télécom, cela signifie l'incapacité de fournir son service principal, avec des pénalités contractuelles importantes, des perturbations pour des millions d'utilisateurs et un impact sur les services d'urgence. La récupération serait extrêmement complexe et longue, car il serait difficile d'isoler et de nettoyer les systèmes infectés sans segmentation. * **Impact Légal et Réglementaire** : Outre le RGPD, le secteur des télécoms est soumis à des réglementations strictes concernant la sécurité et la protection des infrastructures critiques. Une telle vulnérabilité pourrait entraîner la révocation de licences d'exploitation, des sanctions sévères de la part des autorités de régulation et des enquêtes approfondies, mettant en péril l'existence même de l'entreprise. ### 3.

Recommandation:

La correction de l'absence de segmentation est une priorité absolue et doit être abordée comme un projet stratégique majeur. Il s'agit de la mise en œuvre d'une architecture de sécurité "Zero Trust" où aucune entité n'est implicitement fiable, même à l'intérieur du réseau. **Mesures de correction détaillées et actionnables** : 1. **Phase 1 : Audit et Cartographie Détaillée (Préparation)** **Inventaire Complet des Actifs** : Identifier et documenter tous les serveurs, applications, bases de données, équipements réseau, postes de travail, et systèmes OT/IoT (Operational Technology/Internet of Things) connectés au réseau. **Classification des Actifs et des Données** : Classer chaque actif et les données qu'il traite en fonction de leur criticité métier, de leur sensibilité (ex: données personnelles, données financières, données de configuration réseau) et de leur exposition. **Cartographie des Flux de Communication** : Comprendre et documenter précisément les flux de communication légitimes entre les différents systèmes et applications. C'est une étape cruciale pour définir les règles de pare-feu futures (qui doit parler à qui, sur quels ports et protocoles). Des outils d'analyse de flux réseau (NetFlow, sFlow) peuvent être très utiles ici. 2. **Phase 2 : Conception de l'Architecture de Segmentation (Planification)** **Définition des Zones de Sécurité (VLANs et Sous-réseaux)** : Créer des zones logiques distinctes basées sur la fonction, la criticité et le niveau de confiance. Exemples de zones : **DMZ (Demilitarized Zone)** : Pour les services accessibles depuis Internet (serveurs web, VPN). **Zone Utilisateurs** : Postes de travail, imprimantes. **Zone Serveurs Applicatifs** : Serveurs hébergeant les applications métier. **Zone Bases de Données** : Serveurs de bases de données critiques. **Zone Administration/Management** : Pour les outils d'administration système et réseau (accès restreint). **Zone OT/Telecom** : Pour les équipements réseau critiques (routeurs, commutateurs, BSS/OSS). **Zone Développement/Test** : Environnements isolés pour le développement. **Déploiement de Pare-feu Internes (Next-Generation Firewalls - NGFW)** : Positionner des pare-feu robustes aux frontières de chaque zone de sécurité pour filtrer le trafic inter-zones. Ces pare-feu doivent être configurés en mode "Deny by Default" (tout est bloqué par défaut) avec des règles spécifiques autorisant uniquement les flux légitimes identifiés lors de la phase de cartographie. Les NGFW offrent des capacités d'inspection approfondie des paquets (DPI), de prévention d'intrusion (IPS) et de filtrage applicatif. **Implémentation de VLANs et Routage Inter-VLAN** : Configurer les

commutateurs réseau pour créer les VLANs définis et acheminer le trafic entre eux via les pare-feu internes. 3. **Phase 3 : Implémentation et Déploiement Progressif (Exécution)** * **Déploiement par Phases** : Commencer par segmenter les zones les moins critiques ou les plus faciles à isoler, puis progresser vers les zones les plus critiques (bases de données, systèmes de facturation, OSS/BSS). Cela permet de minimiser les risques de perturbation et d'apprendre de chaque étape. * **Tests Rigoureux** : Après chaque phase de segmentation, effectuer des tests approfondis pour s'assurer que les communications légitimes fonctionnent correctement et que les communications non autorisées sont bloquées. Inclure des tests de pénétration internes pour valider l'efficacité de la segmentation. * **Micro-segmentation (Option Avancée)** : Pour les applications ou serveurs les plus critiques, envisager la micro-segmentation. Cela implique d'appliquer des politiques de sécurité au niveau de l'hôte ou de l'application, permettant un contrôle granulaire des communications entre des instances individuelles, même au sein d'un même VLAN. Des solutions basées sur SDN (Software-Defined Networking) ou des pare-feu hôtes peuvent être utilisées. 4. **Phase 4 : Surveillance et Maintenance (Opérations)** * **Surveillance Continue** : Mettre en place des systèmes de supervision (SIEM - Security Information and Event Management) pour collecter et analyser les logs des pare-feu et des équipements réseau. Cela permet de détecter les tentatives d'accès non autorisées et de surveiller l'efficacité de la segmentation. * **Révision Régulière des Règles** : Les règles de pare-feu et les politiques de segmentation doivent être révisées régulièrement pour s'adapter à l'évolution de l'infrastructure et des besoins métier. * **Formation** : Former les équipes réseau et sécurité aux nouvelles architectures et aux bonnes pratiques de gestion de la segmentation. **Ressources nécessaires** : * **Humaines** : Architectes réseau et sécurité, ingénieurs réseau, ingénieurs sécurité, chefs de projet. * **Techniques** : Investissement dans des pare-feu internes (NGFW), commutateurs supportant les VLANs, outils de cartographie réseau et de gestion des flux, SIEM. * **Budget** : Allouer un budget significatif pour l'acquisition de matériel/logiciel et les ressources humaines. **Alternatives possibles (moins robustes mais peuvent servir de mesures transitoires)** : * **Pare-feu hôtes** : Activer et configurer des pare-feu sur chaque serveur et poste de travail pour restreindre les communications entrantes et sortantes. C'est une mesure de défense en profondeur utile, mais ne remplace pas la segmentation réseau. * **ACLs sur les commutateurs** : Utiliser des listes de contrôle d'accès sur les commutateurs de couche 3 pour filtrer le trafic entre les sous-réseaux existants. Moins flexible et moins performant que des pare-feu dédiés. **Meilleures pratiques du secteur** : * **Principe du moindre privilège** : Appliquer ce principe non seulement aux utilisateurs mais aussi aux communications réseau. * **Architecture Zero Trust** : Adopter une approche où la confiance n'est jamais accordée par défaut, même à l'intérieur du réseau. * **Automatisation** : Utiliser des outils d'automatisation pour la gestion des politiques de sécurité et le déploiement. **Priorité d'action** : Cette vulnérabilité est de **priorité CRITIQUE**. L'absence de segmentation est une faille architecturale fondamentale qui expose l'intégralité de l'entreprise à un risque de compromission totale. Elle doit être traitée avec la plus haute urgence et considérée comme le projet de sécurité numéro un. Un plan d'action détaillé avec des jalons clairs et des ressources dédiées doit être mis en place immédiatement.

Finding #3: Firewall obsolète

Catégorie: Network

Sévérité: High

Priorité: P1

Description:

Le firewall identifié (ID preuve: 8655) opère sur une version logicielle qui n'est plus supportée par son éditeur. Cela signifie que le fabricant a cessé de développer des mises à jour de sécurité, des correctifs de bugs ou des améliorations de fonctionnalités pour cette version spécifique. Un équipement réseau, et particulièrement un firewall, est la première ligne de défense d'un système d'information. Son rôle est de filtrer le trafic, d'appliquer des politiques de sécurité et de segmenter le réseau pour protéger les actifs internes contre les menaces externes et internes non autorisées. L'obsolescence de ce firewall expose Nexoryx Bank à des risques critiques. Des vulnérabilités connues (CVEs) spécifiques à cette version non supportée peuvent être exploitées par des attaquants. Ces failles peuvent inclure des vulnérabilités permettant l'exécution de code à distance (RCE), le contournement des règles de filtrage, l'élévation de privilèges, ou des attaques par déni de service (DoS). Dans le contexte du secteur des télécommunications, un firewall compromis peut servir de point d'entrée pour accéder à des infrastructures critiques (réseaux de commutation, systèmes de gestion d'abonnés, plateformes de facturation) ou pour manipuler le trafic réseau, affectant directement la disponibilité et l'intégrité des services de communication. ### **2.

Impact métier:

--- ### **1. Description enrichie de la vulnérabilité** Le firewall identifié (ID preuve: 8655) opère sur une version logicielle qui n'est plus supportée par son éditeur. Cela signifie que le fabricant a cessé de développer des mises à jour de sécurité, des correctifs de bugs ou des améliorations de fonctionnalités pour cette version spécifique. Un équipement réseau, et particulièrement un firewall, est la première ligne de défense d'un système d'information. Son rôle est de filtrer le trafic, d'appliquer des politiques de sécurité et de segmenter le réseau pour protéger les actifs internes contre les menaces externes et internes non autorisées. L'obsolescence de ce firewall expose Nexoryx Bank à des risques critiques. Des vulnérabilités connues (CVEs) spécifiques à cette version non supportée peuvent être exploitées par des attaquants. Ces failles peuvent inclure des vulnérabilités permettant l'exécution de code à distance (RCE), le contournement des règles de filtrage, l'élévation de privilèges, ou des attaques par déni de service (DoS). Dans le contexte du secteur des télécommunications, un firewall compromis peut servir de point d'entrée pour accéder à des infrastructures critiques (réseaux de commutation, systèmes de gestion d'abonnés, plateformes de facturation) ou pour manipuler le trafic réseau, affectant directement la disponibilité et l'intégrité des services de communication. ### **2. Impact métier concret** La présence d'un firewall obsolète et non supporté représente un risque majeur pour les opérations et la réputation de Nexoryx Bank, avec des conséquences bien au-delà de l'aspect technique. *

****Interruption des services et perte de revenus :**** Une exploitation réussie pourrait entraîner un déni de service généralisé, affectant la connectivité et la disponibilité des services de communication pour vos abonnés. Cela se traduirait par une perte directe de revenus due à l'incapacité de fournir des services, des pénalités contractuelles et des coûts opérationnels élevés liés à la gestion de crise et à la restauration des services. *

****Compromission des données et risques réglementaires :**** Le firewall protège potentiellement des données sensibles d'abonnés (informations personnelles, données de localisation, historiques de communication) et des informations opérationnelles critiques. Une brèche de sécurité via ce firewall pourrait entraîner la fuite de ces données, exposant Nexoryx Bank à des amendes réglementaires substantielles (ex: RGPD, lois locales sur la protection des données), des poursuites judiciaires de la part des clients affectés, et des coûts de notification et de remédiation considérables. *

****Atteinte à la réputation et perte de confiance :**** Une faille de sécurité majeure, surtout dans le

secteur des télécommunications où la confiance est primordiale, éroderait gravement la réputation de Nexoryx Bank. La perte de confiance des abonnés et des partenaires pourrait entraîner une désaffection massive, un avantage concurrentiel réduit et des difficultés à attirer de nouveaux clients ou à maintenir les contrats existants. ### **3. Recommandations de correction enrichies** Compte tenu de la sévérité "High" et de l'impact potentiel, l'action corrective doit être prioritaire et menée avec la plus grande diligence.

1. **Mise à niveau ou remplacement immédiat du firewall** :
 - * **Analyse de l'existant** : Identifiez précisément le modèle et la version du firewall. Vérifiez si une mise à niveau vers une version supportée est possible et si elle est compatible avec l'infrastructure actuelle. Si ce n'est pas le cas, un remplacement complet est impératif.
 - * **Planification stratégique** : Élaborez un plan détaillé incluant l'évaluation des besoins actuels et futurs en matière de sécurité réseau, la sélection d'une solution de firewall moderne (matérielle ou logicielle) avec un support éditeur robuste et une feuille de route claire pour les mises à jour.
 - * **Budget et ressources** : Allouez les budgets nécessaires pour l'acquisition, la licence, l'implémentation et la formation des équipes. Mobilisez des ingénieurs réseau et des experts en sécurité pour la conception et le déploiement.
2. **Processus de migration sécurisé** :
 - * **Environnement de test** : Avant tout déploiement en production, configurez et testez la nouvelle solution (ou la version mise à jour) dans un environnement de pré-production. Cela inclut la migration des règles de filtrage existantes, la validation des performances et la détection d'éventuels effets de bord.
 - * **Plan de migration détaillé** : Définissez une stratégie de migration (ex: migration progressive, bascule complète) avec des fenêtres de maintenance planifiées, des plans de rollback en cas de problème, et une communication claire aux parties prenantes.
 - * **Configuration sécurisée** : Appliquez les meilleures pratiques de durcissement (hardening) lors de la configuration du nouveau firewall : désactivation des services inutiles, utilisation de mots de passe forts, activation de l'authentification multi-facteurs pour l'administration, et configuration des logs pour l'intégration à un SIEM.
3. **Gestion du cycle de vie et surveillance continue** :
 - * **Politique de gestion des patches** : Mettez en place une politique stricte de gestion des mises à jour et des patches de sécurité pour tous les équipements réseau, y compris les firewalls. Assurez-vous que les firewalls sont toujours sur des versions supportées et à jour.
 - * **Surveillance et alertes** : Intégrez les logs du nouveau firewall à votre système de gestion des informations et des événements de sécurité (SIEM) pour une surveillance en temps réel des activités suspectes et la détection rapide des tentatives d'intrusion ou des anomalies.
 - * **Audits réguliers** : Planifiez des audits de configuration et des tests d'intrusion réguliers pour valider l'efficacité du firewall et identifier de nouvelles vulnérabilités potentielles.
 - * **Documentation** : Maintenez une documentation à jour des configurations, des politiques de sécurité et des procédures de maintenance.

Priorité d'action : **Élevée (High)**. Cette vulnérabilité représente un risque immédiat et critique pour la sécurité, la disponibilité et la conformité de Nexoryx Bank. Une action corrective urgente est impérative pour prévenir une exploitation potentielle.

Recommandation:

Recommandation générale pour firewall obsolète

Finding #4: MFA absent

Catégorie: IAM

Sévérité: High

Priorité: P1

Description:

L'absence de l'authentification multi-facteurs (MFA - Multi-Factor Authentication) signifie que l'accès aux systèmes et applications ne repose que sur un seul facteur d'authentification, généralement un mot de passe. Cette configuration est intrinsèquement faible et expose Nexoryx Bank à un risque élevé de compromission des comptes utilisateurs. Un attaquant n'a besoin que de dérober ou de deviner un mot de passe pour obtenir un accès non autorisé, sans qu'un second facteur (comme un code généré par une application, une empreinte digitale ou une clé de sécurité physique) ne vienne renforcer cette protection. Dans le contexte d'un pentest réseau pour une banque du secteur des télécoms, cette vulnérabilité est particulièrement critique. Elle pourrait concerner des accès à des systèmes internes (panneaux d'administration, serveurs de gestion de réseau, bases de données clients, outils de gestion financière), des services exposés sur Internet (portails clients, VPN d'accès distant, interfaces d'administration de services cloud) ou même des équipements réseau critiques. Les vecteurs d'attaque sont nombreux : attaques par force brute ou par dictionnaire sur les mots de passe, attaques de "credential stuffing" (réutilisation de couples identifiant/mot de passe volés lors d'autres fuites de données), hameçonnage (phishing) pour dérober les identifiants, ou encore l'utilisation de logiciels malveillants (keyloggers) pour capturer les saisies. Une fois un mot de passe compromis, l'attaquant obtient un accès complet au compte, sans aucune barrière supplémentaire. ### 2.

Impact métier:

L'absence de MFA représente un risque métier majeur pour Nexoryx Bank, avec des conséquences potentiellement dévastatrices bien au-delà des aspects purement techniques. Sur le plan financier, une compromission de compte pourrait mener à des fraudes directes (transferts non autorisés, manipulation de transactions), au vol de données financières sensibles ou à l'interruption de services critiques, entraînant des pertes de revenus significatives et des coûts de remédiation élevés. De plus, les amendes réglementaires, notamment en vertu du RGPD en cas de fuite de données personnelles de clients, ou des régulations spécifiques au secteur bancaire et des télécoms, pourraient se chiffrer en millions d'euros. L'impact réputationnel serait également considérable. Une brèche de sécurité due à une authentification faible éroderait gravement la confiance des clients, des partenaires et des investisseurs, affectant l'image de marque de Nexoryx Bank et sa position concurrentielle. Les conséquences opérationnelles incluent la perturbation des services bancaires et de télécommunications, la paralysie de systèmes critiques, la compromission de données clients (informations personnelles, historiques de transactions) et de données internes (stratégies, propriété intellectuelle), ainsi que le risque de mouvements latéraux d'un attaquant au sein du réseau, menant à une compromission plus large de l'infrastructure. La capacité de Nexoryx Bank à opérer de manière sécurisée et fiable serait directement remise en question. ### 3.

Recommandation:

La mise en œuvre de l'authentification multi-facteurs est une mesure de sécurité fondamentale et doit être une priorité absolue pour Nexoryx Bank. **1. Établissement d'une Politique MFA et Identification des Cibles : ** * **Définir une politique MFA claire et obligatoire : ** La politique doit spécifier quels systèmes, applications et catégories d'utilisateurs (privilegiés, administrateurs, accès externes, clients) sont soumis à l'MFA. * **Priorisation des systèmes critiques : ** Commencer par les systèmes les plus sensibles : accès aux infrastructures réseau (routeurs, commutateurs, pare-feu), serveurs critiques (bases de données clients, systèmes financiers,

serveurs d'identité), accès VPN, portails d'administration, et tous les comptes à privilèges élevés. * **Inventaire des comptes : ** Réaliser un inventaire exhaustif de tous les comptes utilisateurs et des systèmes nécessitant une authentification. **2. Choix des Méthodes MFA et Intégration Technique : ** * **Privilégier les méthodes robustes et résistantes au phishing : ** * **Clés de sécurité physiques (FIDO2/U2F) : ** Pour les comptes à privilèges élevés et les accès critiques, ces clés offrent la meilleure protection contre le phishing. * **Applications d'authentification (TOTP) : ** Des applications comme Google Authenticator, Microsoft Authenticator ou Authy sont de bonnes options pour la plupart des utilisateurs, générant des codes à usage unique. * **Notifications Push : ** Des solutions comme Duo Security ou Okta Verify offrent une expérience utilisateur fluide et sécurisée. * **Éviter le SMS OTP si possible : ** Bien que mieux que rien, le SMS OTP est vulnérable aux attaques de "SIM swapping" et doit être utilisé avec prudence, idéalement comme option de secours uniquement. * **Intégration avec les systèmes d'identité existants : ** * **Utiliser un fournisseur d'identité (IdP) centralisé : ** Intégrer l'MFA avec des solutions comme Active Directory Federation Services (ADFS), Azure AD, Okta, ou Ping Identity pour une gestion cohérente et simplifiée. * **Mettre à jour les applications : ** Les applications web et les services qui ne supportent pas nativement l'MFA devront être mis à jour ou passer par un proxy d'authentification qui gère l'MFA. * **MFA pour les équipements réseau : ** Configurer l'MFA pour les accès SSH, Telnet, et les interfaces web des équipements réseau via RADIUS, TACACS+ ou des solutions propriétaires. **3. Déploiement, Formation et Support : ** * **Déploiement progressif : ** Commencer par un groupe pilote d'utilisateurs pour tester la solution, recueillir les retours et ajuster le processus. * **Campagnes de sensibilisation et de formation : ** Informer les utilisateurs sur l'importance de l'MFA, comment l'activer et l'utiliser. Fournir des guides clairs et un support technique dédié pour faciliter la transition. * **Gestion des exceptions et des récupérations : ** Mettre en place des procédures sécurisées pour la réinitialisation des facteurs MFA perdus ou oubliés, en s'assurant qu'elles ne créent pas de nouvelles vulnérabilités. **4. Surveillance et Audit Continus : ** * **Surveillance des journaux d'authentification : ** Mettre en place une surveillance continue des tentatives d'authentification (réussies et échouées) et des événements liés à l'MFA pour détecter toute activité suspecte. * **Audits réguliers : ** Vérifier régulièrement la conformité des configurations MFA avec la politique de sécurité et s'assurer que tous les systèmes requis sont bien protégés. * **Mise à jour des plans de réponse aux incidents : ** Intégrer les scénarios de contournement ou de défaillance de l'MFA dans les plans de réponse aux incidents. **Priorité d'action : Élevée (High)** Compte tenu du secteur (Banque/Télécom) et de la nature critique des données et services gérés par Nexoryx Bank, l'absence de MFA est une vulnérabilité de haute priorité qui doit être corrigée dans les plus brefs délais. Elle constitue une porte d'entrée facile pour des attaques aux conséquences potentiellement catastrophiques.

Finding #5: Comptes dormants

Catégorie: IAM

Sévérité: Medium

Priorité: P2

Description:

La vulnérabilité identifiée concerne la présence de plus de 50 comptes utilisateurs inactifs, qualifiés de "dormants", qui n'ont pas été désactivés ou supprimés des systèmes d'information de Nexoryx Bank. Un compte dormant est un compte qui a été créé pour un utilisateur (employé, prestataire, système) qui n'est plus en fonction ou qui n'a plus besoin d'accès aux ressources de l'entreprise, mais dont l'accès n'a pas été révoqué. Ces comptes représentent une surface d'attaque inutile et dangereuse. Techniquement, chaque compte dormant est une porte d'entrée potentielle dans le réseau de Nexoryx Bank. Un attaquant externe ou interne pourrait tenter de compromettre ces comptes via diverses méthodes : attaques par force brute, "credential stuffing" (utilisation de paires identifiant/mot de passe volées lors d'autres fuites de données), ou même par ingénierie sociale si l'identité de l'ancien utilisateur est connue. Une fois compromis, un compte dormant, même s'il n'a pas de privilèges élevés, peut servir de point d'ancrage pour un attaquant afin d'effectuer une reconnaissance interne, de pivoter vers d'autres systèmes, d'escalader ses privilèges ou de lancer des attaques de phishing ciblées depuis l'intérieur du réseau. Dans le contexte d'un pentest réseau, la découverte de ces comptes a probablement été réalisée par énumération de services (LDAP, Active Directory, bases de données, applications web) et vérification des dates de dernière connexion ou des statuts d'activité. ### **2.

Impact métier:

La présence de comptes dormants chez Nexoryx Bank, acteur majeur du secteur des Télécoms et de la finance, présente des risques métier significatifs bien au-delà de la simple faille technique. * **Risque Financier et Réputationnel : ** La compromission d'un seul de ces comptes pourrait mener à une intrusion réussie. Un attaquant pourrait alors accéder à des données sensibles (informations clients, données financières, secrets commerciaux liés aux infrastructures télécoms ou aux services bancaires). Cela entraînerait des coûts directs massifs liés à la réponse à incident (investigation forensique, remédiation, communication de crise), des amendes réglementaires potentiellement très lourdes (RGPD, régulations financières spécifiques), et une perte de confiance irréparable de la part des clients, des partenaires et des investisseurs. La réputation de Nexoryx Bank serait gravement entachée, impactant directement sa capacité à attirer et retenir des clients et des talents. * **Risque Légal et de Conformité : ** La gestion des identités et des accès est un pilier fondamental de la conformité réglementaire (RGPD pour la protection des données personnelles, directives de la Banque Centrale Européenne, réglementations sectorielles des télécoms). La non-désactivation de comptes dormants constitue une violation du principe de "moindre privilège" et de "minimisation des données", et démontre une faiblesse dans les contrôles d'accès. En cas d'audit ou d'incident, Nexoryx Bank s'exposerait à des sanctions légales et à des exigences de remédiation coûteuses et contraignantes de la part des autorités de régulation. * **Risque Opérationnel : ** Au-delà des conséquences directes d'une brèche, la maintenance de comptes inutiles complexifie la gestion des identités, rend les audits plus difficiles et augmente la charge de travail des équipes de sécurité et d'administration. En cas d'incident, l'identification de la source et la traçabilité des actions seraient rendues plus ardues par la présence de ces comptes "fantômes", ralentissant la réponse et augmentant le temps d'indisponibilité potentiel des services critiques. ### **3.

Recommandation:

La correction de cette vulnérabilité nécessite une approche structurée combinant des actions immédiates, des améliorations de processus et l'implémentation de contrôles techniques robustes. **3.1. Mesures Correctives Immédiates : ** * **Désactivation/Suppression des Comptes Identifiés : ** Procéder sans délai à la désactivation ou à la suppression (selon la politique de rétention et la criticité du compte) des 50+ comptes dormants identifiés. Avant toute suppression, s'assurer qu'aucune donnée ou ressource critique n'est exclusivement liée à ces comptes. * **Audit Rapide des Privilèges : ** Pour les comptes désactivés, vérifier les privilèges qui leur

étaient associés. Si des comptes dormants avaient des privilèges élevés, cela indique une faille encore plus critique dans la gestion des accès. **3.2. Amélioration des Politiques et Processus IAM (Identity and Access Management)** : **Définition d'une Politique de Cycle de Vie des Comptes** : Établir une politique claire et documentée pour le cycle de vie complet des identités : **Provisioning** : Processus d'attribution des accès lors de l'arrivée d'un nouvel utilisateur. **Modification** : Gestion des changements de rôle ou de statut. **Deprovisioning** : Processus de révocation des accès et de désactivation/suppression des comptes lors du départ d'un utilisateur ou de la fin d'un besoin d'accès. **Définition du Statut "Dormant"** : Établir une définition claire de ce qu'est un compte "dormant" (ex: aucune connexion ou activité enregistrée pendant 60 ou 90 jours). **Processus de Révision Régulière (Recertification)** : Mettre en place un processus formel de révision périodique des accès (annuel ou semestriel) par les responsables métiers. Cela garantit que les utilisateurs ont toujours les accès nécessaires et uniquement ceux-là. **3.3. Implémentation de Contrôles Techniques et d'Automatisation** : **Intégration RH-IAM** : Mettre en place une intégration entre le système de gestion des ressources humaines (SIRH) et les systèmes de gestion des identités (ex: Active Directory, LDAP, solutions IAM dédiées). Cela permet d'automatiser la désactivation des comptes dès qu'un employé quitte l'entreprise ou change de statut. **Scripts de Détection et de Gestion Automatisée** : Développer et déployer des scripts ou utiliser des fonctionnalités natives des systèmes (ex: GPO dans Active Directory) pour : Identifier automatiquement les comptes inactifs selon la politique définie. Générer des alertes pour les équipes de sécurité et d'administration. Désactiver automatiquement les comptes après une période d'inactivité définie, avec une période de grâce avant suppression définitive. **Centralisation des Logs et Monitoring** : Renforcer la collecte et l'analyse des logs d'authentification et d'activité. Un système SIEM (Security Information and Event Management) devrait être configuré pour alerter sur les tentatives de connexion échouées sur des comptes inactifs ou sur des activités inhabituelles. **Authentification Multi-Facteurs (MFA)** : Bien que non directement liée aux comptes dormants, l'extension de l'utilisation du MFA à tous les comptes (y compris les comptes de service et les accès privilégiés) réduit considérablement le risque de compromission même si un compte est découvert et que son mot de passe est faible. **Principe du Moindre Privilège** : S'assurer que tous les comptes, actifs ou non, adhèrent strictement au principe du moindre privilège, limitant ainsi l'impact potentiel en cas de compromission. **3.4. Audit et Sensibilisation** : **Audits Internes Réguliers** : Planifier des audits internes réguliers de la gestion des identités et des accès pour s'assurer de l'application des politiques et de l'efficacité des contrôles. **Sensibilisation** : Sensibiliser les équipes RH, IT et les managers à l'importance d'une gestion rigoureuse des départs et des changements de rôle pour minimiser la création de comptes dormants. **Priorité d'Action** : **Élevée (High)**. Bien que la sévérité initiale soit "Medium", le contexte de Nexoryx Bank (secteur Telecom et Bancaire, données sensibles, infrastructure critique) élève le risque. La présence de plus de 50 comptes dormants indique une faiblesse systémique dans la gestion des identités, ce qui est un point d'entrée majeur pour des attaques sophistiquées. Une action rapide est impérative pour réduire la surface d'attaque.

Finding #6: Mot de passe faible

Catégorie: IAM

Sévérité: Critical

Priorité: P0

Description:

La vulnérabilité identifiée concerne une politique de gestion des mots de passe manifestement faible, couplée à l'absence de rotation régulière des identifiants. Techniquement, cela signifie que les systèmes d'authentification de Nexoryx Bank acceptent des mots de passe qui sont courts, simples, prévisibles, ou qui figurent dans des listes de mots de passe couramment utilisés. L'absence de rotation aggrave le problème en permettant à ces mots de passe faibles de rester actifs indéfiniment, augmentant ainsi la fenêtre d'opportunité pour un attaquant. Cette faiblesse a été mise en évidence par des preuves (ID preuve: 4600) issues de captures d'outils et de logs, indiquant que des comptes utilisateurs ou de service sont protégés par des identifiants facilement devinables ou cassables. Les vecteurs d'attaque sont multiples et directs. Un attaquant peut utiliser des techniques de "brute-force" (tentative systématique de toutes les combinaisons possibles) ou des attaques par dictionnaire (utilisation de listes de mots de passe connus et de leurs variantes) pour compromettre des comptes. De plus, si des utilisateurs réutilisent des mots de passe déjà compromis lors d'autres fuites de données (attaque par "credential stuffing"), l'absence de politique forte et de rotation rend ces comptes extrêmement vulnérables. Dans le contexte d'un pentest réseau pour une entité comme Nexoryx Bank, ces mots de passe faibles pourraient se trouver sur des équipements réseau (routeurs, commutateurs, pare-feu), des serveurs (SSH, RDP), des bases de données, des applications web internes, des interfaces d'administration ou des accès VPN, offrant un point d'entrée critique vers l'infrastructure interne. La sévérité "Critique" est justifiée par le fait qu'un mot de passe faible est souvent la première étape d'une chaîne d'attaque. Une fois qu'un attaquant obtient un accès initial, même à un compte à faibles privilèges, il peut l'utiliser pour escalader ses privilèges, se déplacer latéralement au sein du réseau, et potentiellement accéder à des systèmes critiques contenant des données sensibles (informations clients, données financières, propriété intellectuelle) ou prendre le contrôle d'infrastructures vitales de Nexoryx Bank. #### **2.

Impact métier:

La compromission d'un ou plusieurs comptes via des mots de passe faibles chez Nexoryx Bank aurait des répercussions métier dévastatrices et multidimensionnelles. Sur le plan **financier**, cela pourrait entraîner des pertes directes par fraude (transferts non autorisés, manipulation de transactions), des coûts exorbitants liés à la réponse à incident (investigation forensique, remédiation, communication de crise), et des amendes réglementaires massives (notamment au regard du RGPD pour la fuite de données personnelles et des régulations spécifiques au secteur bancaire). La perturbation des opérations bancaires due à une intrusion pourrait également se traduire par une perte de revenus significative et une augmentation des coûts opérationnels. L'impact sur la **réputation** et la **confiance des clients** serait catastrophique. En tant qu'institution financière, la confiance est le pilier de la relation client. Une brèche de sécurité liée à des mots de passe faibles serait perçue comme un manquement fondamental à la protection des actifs et des données des clients, entraînant une perte massive de clientèle, une dévalorisation de la marque et une couverture médiatique négative prolongée. Sur le plan **légal et réglementaire**, Nexoryx Bank ferait face à des poursuites judiciaires de la part des clients affectés, des enquêtes approfondies des autorités de régulation financière et des autorités de protection des données (CNIL en France, par exemple), avec des sanctions pouvant atteindre des pourcentages significatifs du chiffre d'affaires mondial en cas de non-conformité au RGPD. Enfin, sur le plan **opérationnel**, une intrusion pourrait entraîner des interruptions de service prolongées, une altération de l'intégrité des données, un accès non autorisé à des informations confidentielles et une paralysie des systèmes critiques, menaçant la continuité des activités bancaires. #### **3.

Recommandation:

La correction de cette vulnérabilité critique nécessite une approche holistique, combinant des mesures techniques, organisationnelles et de sensibilisation. La priorité d'action est **Critique**.

1. **Renforcement de la Politique de Mots de Passe (Immédiat et Fondamental)** :
 - Longueur Minimale** : Imposer une longueur minimale d'au moins 12 à 16 caractères pour tous les comptes, et idéalement plus pour les comptes privilégiés.
 - Complexité** : Exiger une combinaison de caractères majuscules, minuscules, chiffres et caractères spéciaux.
 - Interdiction des Mots de Passe Courants** : Mettre en œuvre des listes noires de mots de passe couramment utilisés, de mots de dictionnaire, de séquences simples (ex: "azerty", "123456") et d'informations personnelles (nom d'utilisateur, nom de l'entreprise).
 - Historique des Mots de Passe** : Empêcher la réutilisation des N derniers mots de passe (au moins 5 à 10).
 - Verrouillage de Compte** : Configurer le verrouillage temporaire des comptes après un nombre limité de tentatives de connexion infructueuses (ex: 3 à 5 tentatives en 5 minutes).
 - Changement des Mots de Passe par Défaut** : Exiger le changement immédiat de tout mot de passe par défaut lors de la première connexion pour les nouveaux comptes ou équipements.
2. **Mise en Œuvre de l'Authentification Multi-Facteurs (MFA/2FA) (Priorité Haute)** :
 - Déploiement Généralisé** : Implémenter la MFA pour tous les accès distants (VPN, accès partenaires), les accès aux applications critiques (systèmes bancaires, bases de données clients), les interfaces d'administration, et tous les comptes privilégiés.
 - Méthodes Robustes** : Privilégier des méthodes MFA robustes comme les applications d'authentification (TOTP), les clés de sécurité physiques (FIDO2/U2F) ou les certificats, plutôt que les SMS qui peuvent être vulnérables au "SIM swapping".
3. **Gestion Centralisée des Identités et des Accès (IAM)** :
 - Solution IAM/SSO** : Déployer ou renforcer une solution de gestion des identités et des accès (IAM) et de Single Sign-On (SSO) pour centraliser la gestion des politiques de mots de passe, des comptes utilisateurs et des privilèges, assurant une application cohérente des règles.
 - Provisioning/Deprovisioning** : Automatiser la création et la suppression des comptes pour réduire les risques liés aux comptes orphelins ou non désactivés.
4. **Sensibilisation et Formation des Utilisateurs (Continue)** :
 - Campagnes Régulières** : Organiser des campagnes de sensibilisation régulières pour éduquer les employés sur l'importance des mots de passe forts, les risques liés au partage de mots de passe, au phishing et aux attaques par ingénierie sociale.
 - Outils de Gestion de Mots de Passe** : Encourager et potentiellement fournir des gestionnaires de mots de passe d'entreprise pour aider les utilisateurs à créer et stocker des mots de passe complexes et uniques.
5. **Rotation des Mots de Passe et Surveillance (Continue)** :
 - Rotation Stratégique** : Bien que la tendance moderne soit à des mots de passe très longs et complexes sans expiration forcée (si combinés avec MFA et surveillance), pour Nexoryx Bank, l'absence totale de rotation est un risque majeur. Mettre en place une rotation forcée régulière (ex: tous les 90 jours pour les comptes privilégiés, 180 jours pour les comptes standards) est une mesure de sécurité essentielle à court terme. À long terme, évaluer la possibilité de passer à une politique de non-expiration pour des mots de passe très longs et uniques, complétée par une MFA omniprésente et une surveillance des compromissions.
 - Surveillance des Compromissions** : Utiliser des services de surveillance pour vérifier si les identifiants de Nexoryx Bank apparaissent dans des fuites de données publiques et forcer le changement immédiat des mots de passe concernés.
 - Audit Régulier** : Effectuer des audits réguliers des politiques de mots de passe et des configurations des systèmes pour s'assurer de leur application et de leur efficacité. Utiliser des outils pour identifier les mots de passe faibles existants (via des tests de robustesse sur les hashes de mots de passe, dans un environnement contrôlé et légalement encadré).
 - Ressources Nécessaires** : Équipe IAM/Sécurité IT, budget pour les solutions MFA et IAM, ressources pour la formation et la sensibilisation, support de la direction pour l'application des politiques.

Plan d'Action Priorisé

Plan d'action priorisé pour la remédiation des vulnérabilités.

#	Mesure	Priorité	Responsable	Deadline
1		P3	---	---
2		P0		
3		P3	P0	RSSI / SysAdmin
4		P3	P0SysAdmin / HR (communication)	
5		P3	P0	NetOps / RSSI
6		P3	P0	NetOps
7		P1		
8		P3	P1	NetOps / RSSI
9		P3	P1	NetOps
10		P3	P1	NetOps / SysAdmin
11		P3	P1	NetOps / SysAdmin
12		P3	P1	SysAdmin / RSSI
13		P3	P1	SysAdmin
14		P2		
15		P3	P2	SysAdmin / HR
16		P3	P2	SysAdmin / HR
17		P3	P2	SysAdmin
18		P3	P2	NetOps

Conclusion

L'audit de pénétration réseau mené chez Nexoryx Bank a mis en évidence un niveau de sécurité qui, bien que reposant sur des bases existantes, présente des vulnérabilités significatives nécessitant une attention immédiate. Les 6 constats identifiés, dont 2 de criticité 'Critique' et 3 de criticité 'Élevée', indiquent des risques potentiels d'accès non autorisé à des systèmes critiques et de compromission de données. Ces faiblesses sont particulièrement préoccupantes pour une entité du secteur bancaire opérant dans un environnement télécom exigeant, où la continuité de service et la protection des informations sont primordiales. Il est impératif d'adresser ces points pour renforcer la posture de sécurité globale de l'organisation. **2.

Points positifs:

- Présence de mécanismes de défense périmétriques : ** L'existence de pare-feu et d'autres dispositifs de sécurité en périphérie a été notée, ralentissant certaines tentatives d'intrusion initiales.
- Certains segments réseau bien gérés : ** Des zones spécifiques du réseau interne ont montré une meilleure résilience et une configuration plus robuste, indiquant une expertise technique localisée.
- Réactivité de l'équipe technique : ** L'équipe de Nexoryx Bank a fait preuve de réactivité lors de certaines phases de l'audit, facilitant la communication et la compréhension des environnements.
- Existence de politiques de sécurité initiales : ** Des ébauches de politiques ou de procédures de sécurité ont été identifiées, servant de point de départ pour une formalisation plus poussée.
- 3.

Axes d'amélioration:

- Gestion des vulnérabilités et des patchs : ** Les vulnérabilités critiques soulignent un besoin urgent de renforcer les processus de gestion des patchs et de durcissement des configurations sur les systèmes exposés et critiques.
- Segmentation et isolation réseau : ** Une segmentation insuffisante entre les zones de confiance et les systèmes sensibles a été observée, augmentant le risque de mouvement latéral en cas de compromission initiale.
- Authentification et gestion des accès : ** Des faiblesses dans les mécanismes d'authentification et de gestion des accès sur certains services critiques ont été exploitées, nécessitant une révision des politiques et l'implémentation de l'authentification multifacteur (MFA) là où applicable.
- Durcissement des configurations des services exposés : ** Plusieurs services et équipements présentaient des configurations par défaut ou sub-optimales, offrant des points d'entrée exploitables.
- 4.

Recommandations stratégiques:

- Renforcer la gouvernance de la cybersécurité :** Mettre en place ou consolider un comité de sécurité régulier, avec des représentants de la direction, pour définir et suivre une feuille de route de sécurité claire et alignée sur les risques métier et les exigences réglementaires du secteur bancaire et télécom.
- Investir dans un programme de gestion des vulnérabilités continu :** Au-delà des correctifs immédiats, établir un programme proactif incluant des scans réguliers, des revues de configuration et des pentests périodiques pour maintenir un niveau de sécurité élevé et évolutif.
- Développer la culture de la cybersécurité :** Sensibiliser l'ensemble du personnel, y compris les équipes techniques et opérationnelles, aux bonnes pratiques de sécurité, aux risques spécifiques et à l'importance de la conformité dans un environnement bancaire et télécom.
- Établir un plan de réponse aux incidents (PRI) robuste et testé :** S'assurer que Nexoryx Bank dispose d'un PRI testé et mis à jour, capable de gérer efficacement les incidents de sécurité majeurs, de la détection à la récupération, en minimisant l'impact sur les opérations et la réputation.
- 5.

Nous recommandons à Nexoryx Bank d'élaborer un plan d'action détaillé pour adresser les vulnérabilités identifiées, en priorisant les constats 'Critiques' et 'Élevés'. Un audit de révérification (re-test) des correctifs est fortement conseillé dans les 3 à 6 mois suivant la mise en œuvre des mesures. Notre équipe reste à votre disposition pour toute assistance dans l'interprétation de ce rapport et l'élaboration de votre stratégie de renforcement de la sécurité, afin de garantir une amélioration continue de votre posture de cybersécurité.